RESUMEN

Módulo 4: Malware y TTPs

- ✓ Los tipos de malware (virus, worm, ransomware, infostealer, RAT, dropper…) tienen objetivos distintos que definen qué evidencia buscar.
- ✓ El malware se entiende mejor por lo que hace que por cómo se llama. La secuencia de comportamientos es más importante que una alerta aislada.
- ✓ La ejecución inicial muchas veces empieza con el usuario: adjuntos, macros, LNK, scripts, instaladores falsos o phishing.
- ✓ LOLBins son herramientas legítimas abusadas. El proceso padre, la línea de comandos y la ruta definen si es sospechoso.
- ✓ La persistencia indica que la amenaza intenta mantenerse activa. Puede ser tarea, Run Key, servicio, cuenta, regla de correo o MFA.
- ✓ C2 no siempre usa puertos raros. El beaconing, el proceso y el destino son los factores más discriminantes.
- ✓ El movimiento lateral puede parecer actividad legítima de IT. El ticket, el usuario, el host origen y el horario diferencian.
- ✓ La exfiltración se analiza como secuencia: acceso → recolección → compresión → transferencia. No se confirma solo por volumen.
- ✓ MITRE ATT&CK y Kill Chain ayudan a ordenar el análisis y comunicar mejor — no reemplazan la evidencia ni el criterio.

La pregunta que une todo el módulo: ¿Qué está intentando hacer esta actividad, qué evidencia tengo y qué riesgo representa?

⚠️ Errores comunes del Analista SOC — Módulo 4

✘ Cerrar por detección bloqueada

✔️ Bloqueado reduce riesgo pero no cierra el análisis. Revisar si hubo ejecución previa, persistencia y alcance.

✘ Confirmar malware solo por nombre de detección

✔️ 'Trojan.Generic' no explica qué hizo. Analizar comportamiento: ejecución, persistencia, red.

✘ Ignorar PowerShell porque 'es normal'

✔️ No revisar línea de comandos ni proceso padre es el error más frecuente.

✘ Ver 443 y asumir que es legítimo

✔️ El puerto no define el riesgo. El proceso, el destino, la frecuencia y el contexto lo definen.

✘ Confirmar C2 o ransomware sin evidencia suficiente

✔️ Usar términos como C2 o ransomware sin evidencia daña la credibilidad del análisis.

✘ Ignorar tráfico interno porque 'es confiable'

✔️ Un atacante que ya entró usa protocolos internos. SMB masivo desde endpoint no técnico requiere análisis.

✘ No documentar la secuencia completa

✔️ 'Se detectó malware' no es documentación. Explicar qué ocurrió, en qué orden y por qué importa.

✘ No revisar identidad en casos de phishing

✔️ Un phishing de credenciales no genera malware en endpoint. El análisis es de identidad, sesiones y mailbox.



HIDDEN SECURITY

Modern SOC Operations — Módulo 4